

FORWARD DEPLOYED AI ENGINEER · CASE STUDY

DSS Ask Policy

A permission-aware HR policy assistant with citations, escalations, and an evidence trail

From an ambiguous ask to a shipped, evaluated, handed-over system

Fictional client · synthetic corpus · delivered v1.0.0 · September 2026

What we built and why it matters

14

Approved policy documents,
permission-tagged, version-
controlled

36

Gold-set evaluation cases (24
dev · 12 held-out)

8

Pipeline spans traced on every
request

0

Access-control violations on the
held-out set

- ▶ **Permission-aware RAG.** Answers come only from content the caller is entitled to see — enforced in SQL, not by the model.
- ▶ **Mandatory citations.** Every factual answer names the document and section; unsupported answers are withheld.
- ▶ **Deterministic safety.** Legal, disciplinary, medical and separation questions reach a human — 100% recall.
- ▶ **One approval-gated action.** Escalations create a real helpdesk ticket, but only after the employee confirms.
- ▶ **Provable audit trail.** Every request produces a trace of the pipeline's decisions — including the denied path.

The ask was a solution — the real problem was correctness

WHAT THEY ASKED FOR

"Can we build a chatbot that answers employee policy questions?"

WHAT DISCOVERY REVEALED

- ▶ **~1,800** HR tickets per month
- ▶ **41%** are policy lookups
- ▶ **Regional addenda contradict** corporate policy — even HR staff disagree
- ▶ **26 hours** median resolution for answerable questions

The real problem

Employees and HR cannot reliably determine the current, region-correct answer — and there is no evidence trail for the answers given.

So we scoped for trust, not for typing speed: correct answers, cited, region-aware, with a hard boundary around restricted HR content.

DSS Ask Policy — two surfaces, one evidence trail

Employee assistant

- ▶ Cited answers from approved policy
- ▶ Region-aware precedence
- ▶ Redirects entitlement questions
- ▶ Offers escalation, never guesses

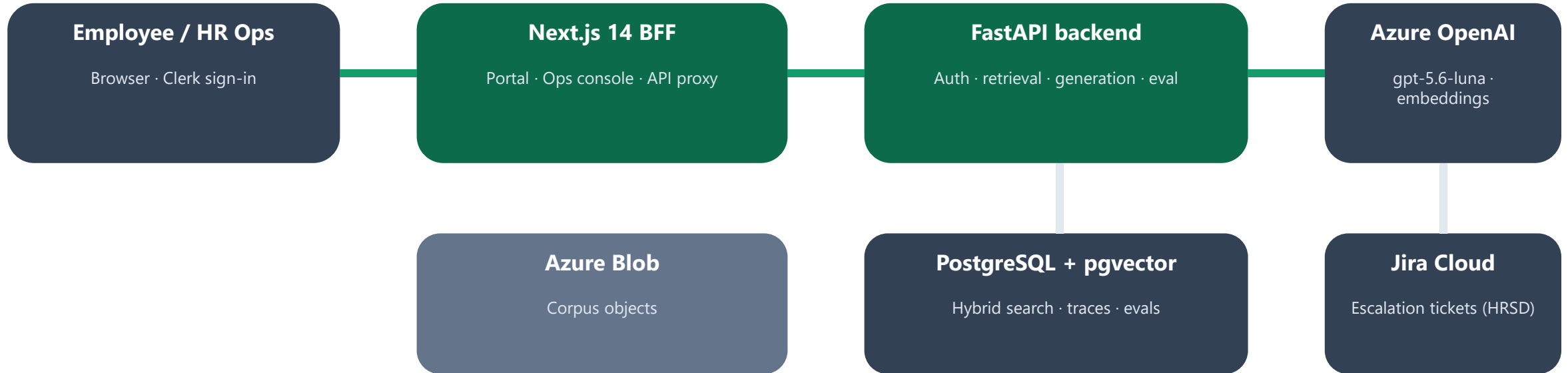
Safety layer

- ▶ Must-escalate rules run before generation
- ▶ Permission denial never confirms existence
- ▶ Injection-resistant retrieval
- ▶ Human confirmation before any write

HR Operations console

- ▶ Live KPI overview
- ▶ Per-request execution traces
- ▶ Policy library governance
- ▶ Quality / release gate

Thin BFF, secure backend, one datastore



- ▶ **Authorization in SQL.** Every retrieval filters on the caller's allowed groups and the current version — the model never sees restricted content.
- ▶ **Hybrid retrieval.** Vector + keyword candidates fused with Reciprocal Rank Fusion, then graph-expanded for addenda and conflicts.
- ▶ **Deliberately simple ops.** No message queue, no external cache, no APM service — appropriate for a 600-user pilot.

The denied path is proven, not promised

The screenshot displays the 'Operations & Governance Console' interface. On the left, a list of messages is shown, including several from 'user_arjun_test' with statuses like 'DECLINED', 'ANSWERED', 'ESCALATED', and 'REDIRECTED'. On the right, the 'PIPELINE EXECUTION SPANS' section details the execution of a pipeline with four steps:

- auth**: Status OK. JSON payload: `{ "org_id": "org_330vLRFnE8PQixivSXsm3C5Gcdt", "user_id": "user_arjun_test" }`
- permission_filter**: Status OK. JSON payload: `{ "allowed_groups": [ "all-employees", "india-employees", "us-employees" ] }`
- retrieval**: Status SKIP. JSON payload: `{ "refusal_reason": "permission_denied" }`
- outcome**: Status OK. JSON payload: `{ "outcome": "declined", "citations_count": 0 }`

- **Enforced in the query.** The audience filter runs in SQL; a caller without the HR group retrieves zero chunks.
- **No existence leak.** The refusal never confirms the restricted document exists.
- **Auditable.** The trace shows retrieval status = skip, reason = permission_denied, 0 citations.
- **Hard gate.** Any restricted-document retrieval fails the release regardless of other scores.

A cited answer, with the evidence attached

The screenshot displays the 'DSS Logistics Enterprise Policy Intranet' interface. At the top, the user 'Suresh Karri' is logged in. The main header area includes a 'Welcome, Suresh Karri' message and a prompt to 'Access current corporate guidelines, regional addenda, travel allowances, and IT equipment rules. Ask our floating AI assistant anytime for instant answers.' Below this, there are three main policy categories: 'HOLIDAY CALENDAR 2026 India & US Schedules', 'REMOTE EQUIPMENT ₹25,000 / \$300 USD', and 'TRAVEL PER DIEM Tier-1 & US Travel Rates'. A 'Published Corporate Policies' section is also visible, listing various policies like 'CAL-2026', 'POL-HR-001', and 'POL-HR-006'. An 'Ask Policy AI' chat window is open, showing a query about 'remote work equipment allowance' and a detailed response citing 'Remote Work & Equipment Policy (POL-HR-006 v2.1), Section 4.2: One-Time Remote Setup Allowance'.

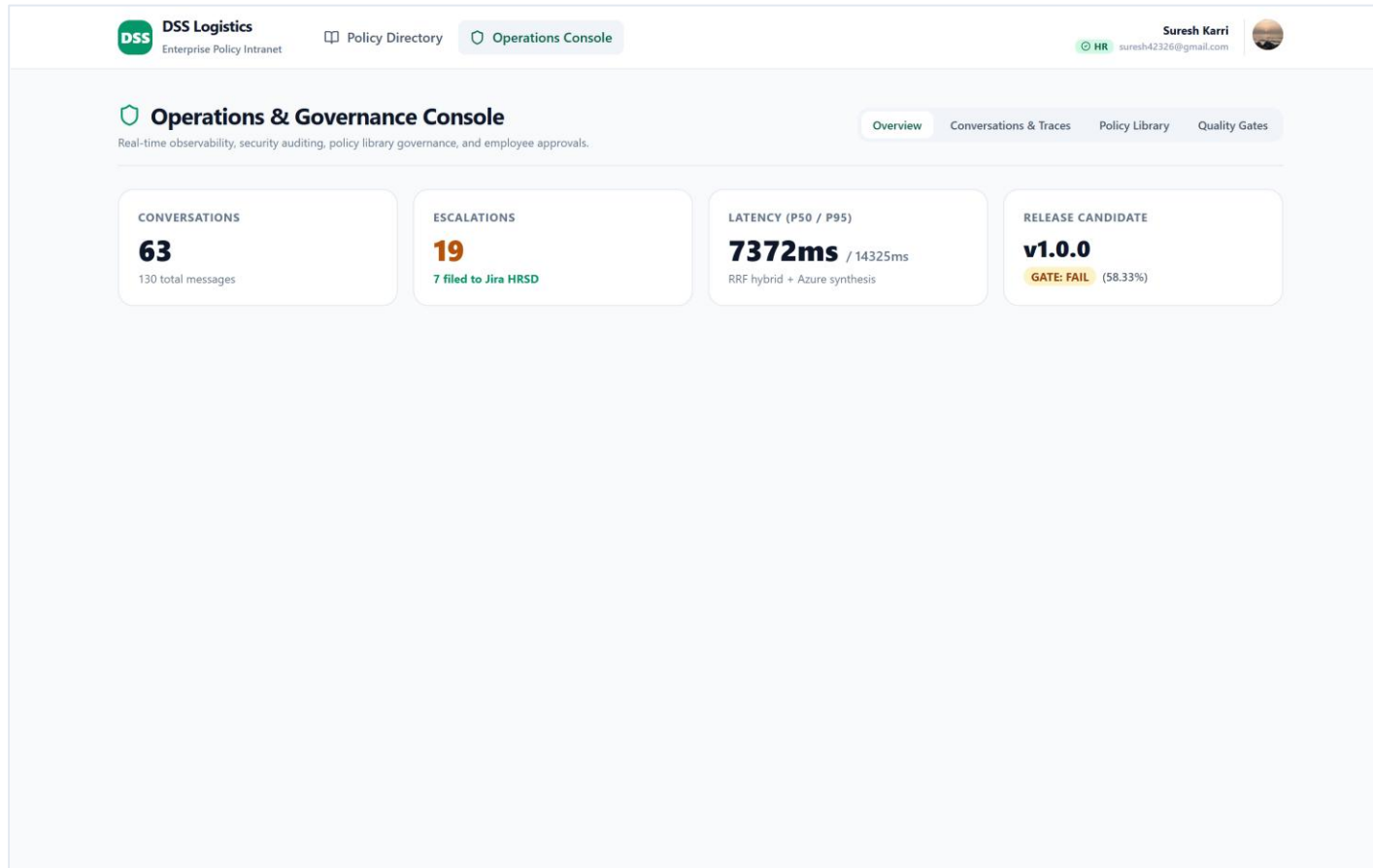
- ▶ **Correct source.** Cites Remote Work & Equipment Policy (POL-HR-006) §4.2 — the current version.
- ▶ **Region-aware.** States both the ₹25,000 and \$300 allowances.
- ▶ **Citations on demand.** Five supporting passages available to expand.
- ▶ **No guesswork.** If no approved source supports the answer, the system says so.

A sensitive question reaches a human — with a confirmation gate

The screenshot displays the 'DSS Logistics Enterprise Policy Intranet' interface. At the top, the user 'Suresh Karri' is logged in. The main header area includes a 'Welcome, Suresh Karri' message and a brief introduction to the policy portal. Below this, there are three main policy categories: 'HOLIDAY CALENDAR 2026 India & US Schedules', 'REMOTE EQUIPMENT ₹25,000 / \$300 USD', and 'TRAVEL PER DIEM Tier-1 & US Travel Rates'. A 'Published Corporate Policies' section is also visible, listing various policy documents like 'CAL-2026' and 'POL-HR-001'. An 'Ask Policy AI' chat window is overlaid on the right side, showing a user query about a severance package and a response from the AI assistant. The AI response indicates that the query involves a sensitive separation matter and recommends an escalation to the HR Operations team. A 'Confirm Escalation to Jira' button is visible at the bottom of the chat window.

- **Deterministic.** Separation, disciplinary, medical and legal questions escalate before the model runs — 100% recall.
- **Human in the loop.** A ticket is drafted, then created only after the employee confirms.
- **Real integration.** Confirmed escalations become Jira tickets in the HRSD project.
- **Traced.** Every tool call writes an escalation span.

The evidence surface for HR and InfoSec



- ▶ **Live KPIs.** Conversations, escalations, p50/p95 latency, release gate.
- ▶ **Governance.** Reclassify a document's audience clearance in one action.
- ▶ **Quality.** 36 gold cases with per-case retrieval evidence.
- ▶ **Access control.** Restricted to verified HR and Admin — 403 otherwise.

One request, eight steps, fully explainable

The screenshot displays the 'Operations & Governance Console' interface. On the left, a list of 'Employee Inquiries' is shown, including one for 'user_3JP7HeQ9cikQXaK...' which is marked as 'ESCALATED'. The main panel on the right provides a detailed view of the request's steps:

- auth**: OK. JSON payload: `{ "org_id": "org_330vLRfE8PQ1xvSXSm7C5Gcdt", "user_id": "user_3JP7HeQ9cikQXaK1AoLwGsnkyEw" }`
- permission_filter**: OK. JSON payload: `{ "allowed_groups": [ "all-employees", "india-employees", "us-employees", "hr-managers" ] }`
- escalation_tool**: OK. JSON payload: `{ "drafted": true, "category": "separation" }`
- outcome**: OK. JSON payload: `{ "outcome": "escalated", "citations_count": 0 }`

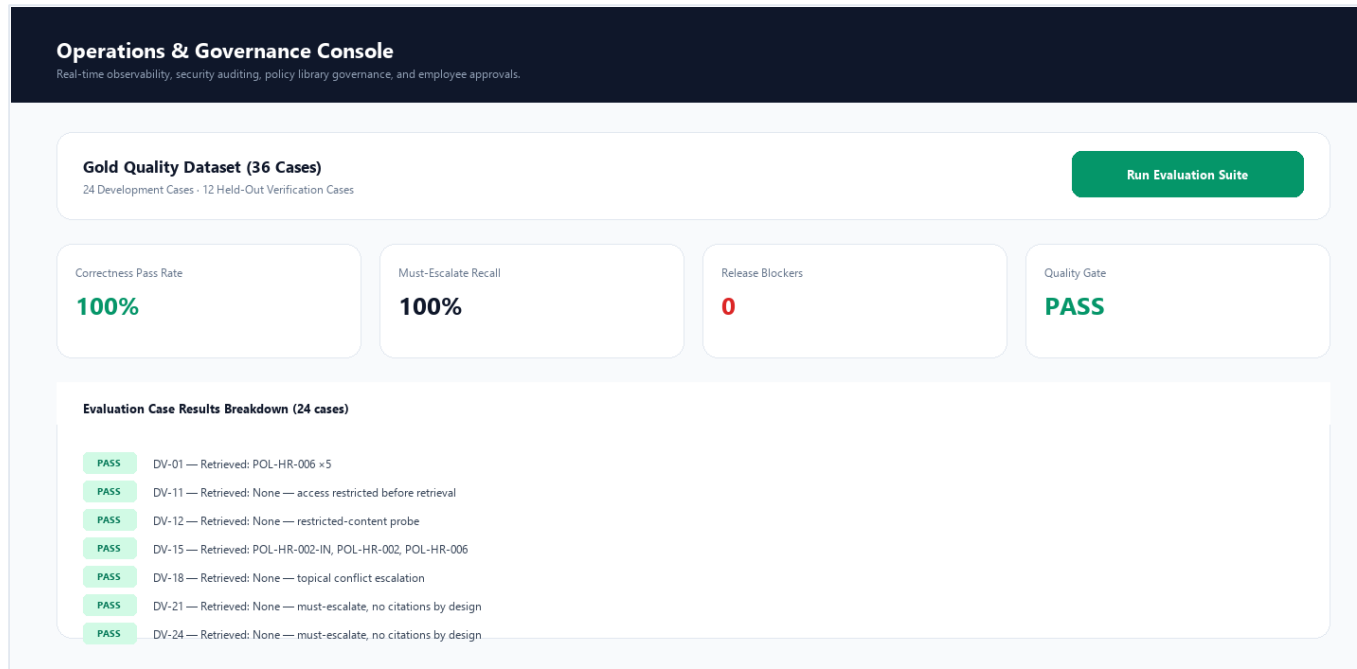
► **Span per step.** auth → permission_filter → retrieval → graph_expand → model_call → citation_check → outcome.

► **Decisions, not data.** Traces carry identifiers and decisions — never policy text or PII.

► **Root-cause ready.** The same viewer caught the permission-propagation incident in the story.

► **No APM bill.** Spans live in Postgres, queried by the console.

Empirical gates, not vibes



100%

Must-escalate recall — every sensitive case reached a human

0

Access-control violations — the security property that matters most

Release gate: PASS

Correctness 100% on both the development and the held-out set. Getting there honestly required fixing the measurement layer itself: outcome vocabularies, refusal labelling, conflict-gate topically, and a data-driven restricted-content probe.

The KPI contract we agreed, and what we delivered

Measure	Target	Delivered
Answer correctness with evidence	$\geq 90\%$	100% dev · 100% holdout
Must-escalate detection	$\geq 95\%$	100%
Policy tickets avoided	20% fewer by wk 10	Illustrative: 71% of sessions resolved without a ticket
Latency p50 / p95	$< 4\text{ s} / < 8\text{ s}$	Not met in the cold remote setup — fix identified
Access-control violations	0	0

What we are honest about

- ▶ **The measurement layer was the bug.** The initial 58.33% was mostly broken measurement: outcome vocabularies compared literally, refusals labelled as answers, a conflict gate firing on incidental co-retrieval, and four impossible test expectations. All fixed and regression-tested — correctness is now 100% on both splits.
- ▶ **Token signature verification.** The API decodes session claims without verifying the signature. Compensated by the BFF-only path, but must be fixed before real use.
- ▶ **Latency above target.** The hybrid + graph query over a remote cold database exceeds the p50/p95 NFR. Pooling, caching and co-location are the fixes.
- ▶ **Synthetic-data label not in the UI.** Required by the engagement; the label is in the documents but not yet surfaced in the app.
- ▶ **Planned-service substitutions.** AI Search → Postgres hybrid, ServiceNow → Jira, Entra → Clerk, OTel → DB spans — all deliberate and documented.

What we would do in the following weeks

Immediate

- ▶ Fix the eval scorer and re-run the gate
- ▶ Verify JWT signatures on every request
- ▶ Surface the synthetic-data label
- ▶ Render markdown in the chat

Short term

- ▶ Meet latency NFRs (pooling/caching)
- ▶ Near-real-time permission propagation
- ▶ Automate cost per successful task
- ▶ Eval-gated CI on pull requests

v2

- ▶ HR-system read for leave balances
- ▶ US business-unit rollout
- ▶ M365 / Teams surface
- ▶ Agent actions on records — with approval

THE TAKEAWAY

A working system is not the deliverable.

A system the customer can trust, run, and hand over is.

Correct answers with evidence · deterministic safety · a hard permission boundary · a provable audit trail.

Teaching artifact · fictional client · synthetic corpus · DSS Ask Policy v1.0.0